Lab 5: Static Code Analysis

Name: Sonu Akash Soundararajan | SRN: PES1UG24AM908 | Program: Loan Eligibility and EMI Calculator (`loan_calculator.py`)

Repo: github.com/SonuAkash-collab/PES1UG24AM908_SE_LAB1 (folder `Lab5/57_loan_eligibility`)

1. Objective and tools

Static analysis checks source code without running it. Three tools were run on the assigned file: **Pylint** (code quality and logic), **Bandit** (security) and **Flake8** (PEP 8 style). The targets were: fix all Bandit findings, get Pylint above 9.5, and clear all Flake8 findings.

2. Results

Tool	Before	After
Pylint	5.17 / 10 (43 messages)	10.00 / 10
Bandit	8 issues: 2 High, 1 Medium, 5 Low	0 issues
Flake8	21 issues	0 issues

The raw reports are in `reports/before/` and `reports/after/` (`pylint_report.txt, bandit_report.txt, flake8_report.txt`).

3. Commits

#	Commit message	What it covers
1	Fix Bandit security issues	FTP to SFTP, marshal to JSON, hardcoded password to env vars, random to secrets, subprocess to smtplib; adds the before reports
2	Fix Pylint issues and logic bugs	Score 5.17 to 10.00; naming, docstrings, mutable default, logic bugs
3	Fix Flake8 formatting issues and add final reports	Blank lines, line length; adds the after reports, issues.md and this report

4. Issues found and how they were fixed

4.1 Security (Bandit) - commit 1

Issue	Severity	Line(s)	Description	Fix approach
FTP used (B402, B321)	High	3, 68	Plain FTP sends login and report unencrypted.	Replaced ftplib with SFTP via paramiko; unknown host keys rejected.
marshal.loads (B302)	Medium	64	Deserialising with marshal is unsafe and version-specific.	Store the loan book as JSON.
Hardcoded password (B107)	Low	67	password="Bureau#2024" committed in source.	Read LOAN_BUREAU_USER / LOAN_BUREAU_PASSWORD from environment variables.
random for IDs (B311)	Low	51	random is predictable; IDs could be guessed.	Use secrets.randbelow.
subprocess + mail (B404, B603, B607)	Low	6, 74	External program found via PATH with user input.	Send email with smtplib / EmailMessage; no subprocess.

4.2 Code quality and bugs (Pylint, plus found by running the program) - commit 2

Issue	Type	Line(s)	Description	Fix approach
Mutable default arg history=[] (W0102)	Bug	20	One list shared by every call, so history leaks between calls.	Default None, create the list inside; made keyword-only.
max_loan_amount ignores rate (W0613)	Bug	33-38	Adds the available amount for every month with no interest, giving 900,000 instead of about 722,600.	Invert the EMI formula to get the supportable principal.

Issue	Type	Line(s)	Description	Fix approach
Unknown loan type approved	Bug	24-29	A 'crypto' loan returned True: the score/income shortcut ran before the loan-type check.	Check loan type first; reject anything not in VALID_LOAN_TYPES.
Wrong rate in demo	Bug	94	calculateEMI(500000, 9, 5) used 9, not 0.09, printing an EMI of 375,000.	Pass 0.09 (now about 10,379).
Division by zero	Bug	14-18, 26	calculate_emi fails at 0% interest; check_eligibility fails at income 0.	Rate 0 handled as principal/months; income <= 0 rejected.
Built-in 'sum' shadowed, unused variable, unused import (W0622, W0612, W0611)	Warning	2, 34-36	Shadowing a built-in and dead code.	Removed; loop replaced by a closed formula.
global statement (W0603)	Warning	62	Rebinding a module global.	Update the dict in place with clear()/update().
Files opened without 'with' (R1732)	Refactor	56, 63, 70	File left open if an exception occurs.	Use with open(...).
camelCase names (C0103)	Convention	14-81	Not PEP 8 snake_case.	Renamed all functions.
Missing docstrings (C0114, C0116)	Convention	all	No module or function documentation.	Added docstrings.
Redundant else/elif, or-chain, parens, f-string (R1705, R1714, R1703, C0325, W1309)	Refactor	28, 79, 82-91, 104	Needlessly verbose code.	Direct returns, 'in', plain strings.
Too many arguments (R0913)	Refactor	20	check_eligibility has 6 parameters.	Kept to avoid changing the public API; silenced with a commented disable-next.
Demo ran on import	Design	93, 106	main() ran whenever the module was imported.	Added if __name__ == "__main__".

4.3 Style (Flake8) - commit 3

Issue	Type	Line(s)	Description	Fix approach
E302 / E305	Style	14-106	Two blank lines needed around top-level functions.	Added them.
E501 line too long	Style	20, 55, 70, 78, 95, 96, 100	Lines over 79 characters.	Wrapped long calls, dicts and strings.
F401 / F541	Style	2, 104	Unused import; f-string without placeholders.	Removed (already fixed in the Pylint commit).

5. Program output before and after

Demo line	Before	After
EMI for 5L @ 9% for 5 years	375000.00 (wrong)	10379.18
Eligible, unknown loan type 'crypto'	True (wrong)	False
Max loan for income 40000, EMIs 5000	900000.0 (ignores interest)	722600.60
Other lines (schedule, risk band, interest saved, save/load)	unchanged	unchanged

6. Verification

The three tools were re-run on the pushed code in a fresh clone of the repo:

```
python -m pylint loan_calculator.py        -> rated 10.00/10
python -m bandit -r loan_calculator.py     -> No issues identified
python -m flake8 loan_calculator.py        -> (no output)
```

Notes: real SFTP upload needs `pip install paramiko` (the demo does not use it). The score-or-income shortcut in check_eligibility (score above 750 or income above 25000 skips the FOIR check) was kept as the original business rule.